

1.0 Introduction

In this lab, we explored various LDAP enumeration techniques to identify critical information within the Active Directory (AD) environment. By leveraging specific ldapsearch commands, we gathered details such as user accounts, group memberships, and nested Domain Admin privileges. These enumeration steps are fundamental in penetration testing, as they help reveal potential attack paths and high-value targets within the domain.

1.1 Executive Summary

Our LDAP queries successfully uncovered key AD data, including all user accounts (sAMAccountName attributes), group memberships (memberof attributes), and nested Domain Admin members via the 1.2.840.113556.1.4.1941 matching rule. The results showed several privileged accounts, confirming the presence of elevated rights and underscoring the importance of securing group membership and account management in an AD environment. These findings emphasize how thorough enumeration can guide defenders to tighten security and help attackers to pinpoint potential escalation routes.

Contents

1.0 Introduction..... 1

1.1 Executive Summary..... 1

2.0 LDAP base Search..... 1

2.1 LDAP sAMAccountName Search..... 3

3.0 LDAP memberof Search 3

4.0 LDAP sAMAccountName Admin Search 5

5.0 Nested User Creation..... 6

6.0 LDAP Search and Windapsearch..... 9

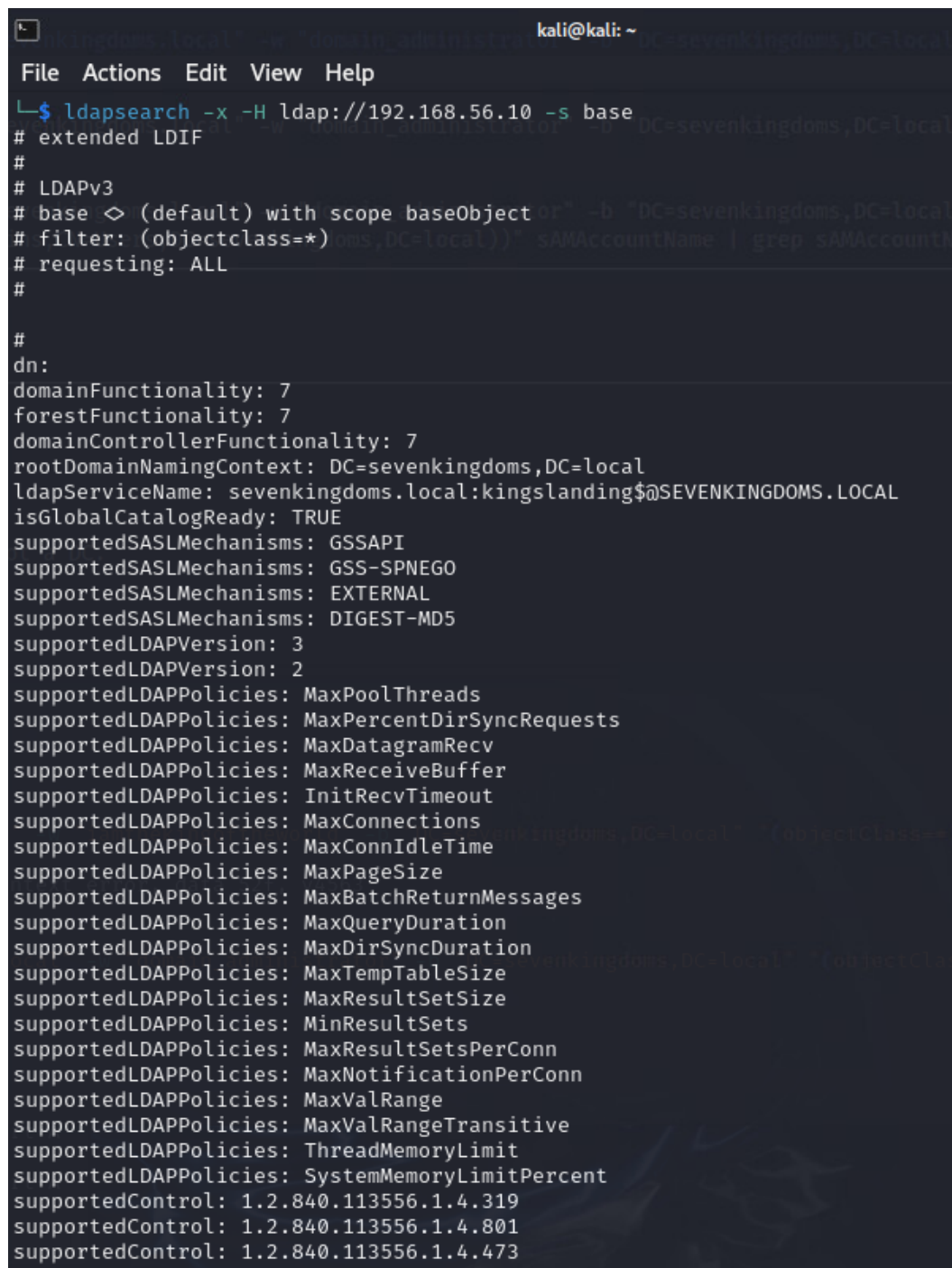
2.0 LDAP base Search

Command Used (IN POWERSHELL):

```
ldapsearch -x -H ldap://192.168.56.10 -s base
```

Findings:

- This command performs an anonymous bind (-x) to the LDAP service on the domain controller at 192.168.56.12 and queries the Root DSE (-s base). The Root DSE contains high-level information about the LDAP server.



```
kali@kali: ~  
File Actions Edit View Help  
$ ldapsearch -x -H ldap://192.168.56.10 -s base  
# extended LDIF  
#  
# LDAPv3  
# base <> (default) with scope baseObject or" -b "DC=sevenkingdoms,DC=local"  
# filter: (objectclass=*)  
# requesting: ALL  
#  
#  
dn:  
domainFunctionality: 7  
forestFunctionality: 7  
domainControllerFunctionality: 7  
rootDomainNamingContext: DC=sevenkingdoms,DC=local  
ldapServiceName: sevenkingdoms.local:kingslanding$@SEVENKINGDOMS.LOCAL  
isGlobalCatalogReady: TRUE  
supportedSASLMechanisms: GSSAPI  
supportedSASLMechanisms: GSS-SPNEGO  
supportedSASLMechanisms: EXTERNAL  
supportedSASLMechanisms: DIGEST-MD5  
supportedLDAPVersion: 3  
supportedLDAPVersion: 2  
supportedLDAPPolicies: MaxPoolThreads  
supportedLDAPPolicies: MaxPercentDirSyncRequests  
supportedLDAPPolicies: MaxDatagramRecv  
supportedLDAPPolicies: MaxReceiveBuffer  
supportedLDAPPolicies: InitRecvTimeout  
supportedLDAPPolicies: MaxConnections  
supportedLDAPPolicies: MaxConnIdleTime  
supportedLDAPPolicies: MaxPageSize  
supportedLDAPPolicies: MaxBatchReturnMessages  
supportedLDAPPolicies: MaxQueryDuration  
supportedLDAPPolicies: MaxDirSyncDuration  
supportedLDAPPolicies: MaxTempTableSize  
supportedLDAPPolicies: MaxResultSetSize  
supportedLDAPPolicies: MinResultSets  
supportedLDAPPolicies: MaxResultSetsPerConn  
supportedLDAPPolicies: MaxNotificationPerConn  
supportedLDAPPolicies: MaxValRange  
supportedLDAPPolicies: MaxValRangeTransitive  
supportedLDAPPolicies: ThreadMemoryLimit  
supportedLDAPPolicies: SystemMemoryLimitPercent  
supportedControl: 1.2.840.113556.1.4.319  
supportedControl: 1.2.840.113556.1.4.801  
supportedControl: 1.2.840.113556.1.4.473
```

Image 2.0a: Displays the Root DSE output, including: namingContexts: DC=essos,DC=local, confirming that the domain name is essos.local.

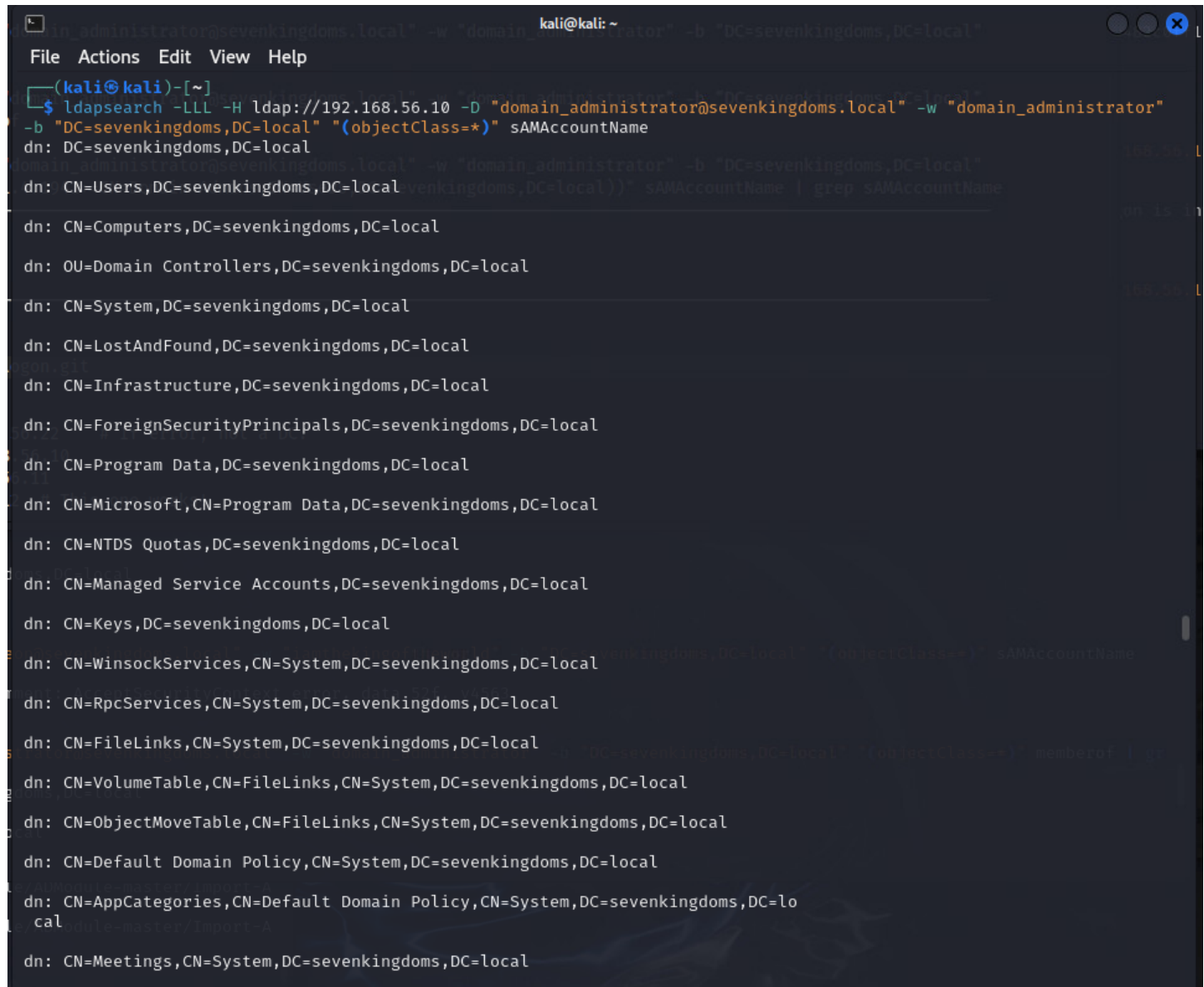
2.1 LDAP sAMAccountName Search

Command Used (IN POWERSHELL):

```
ldapsearch -LLL -H ldap://192.168.56.10 -D "domain_administrator@sevenkingdoms.local" -w "domain_administrator" -b "DC=sevenkingdoms,DC=local" "(objectClass=*)" sAMAccountName
```

Findings:

- From the execution of this command, we see a list of sAMAccountName values for various Active Directory objects. Such as: users, groups, and service accounts. This confirms the domain structure is populated with standard and potentially custom accounts (Administrator, Guest, etc.), which can be leveraged for further reconnaissance or access attempts.



```
File Actions Edit View Help
(kali@kali)-[~]
$ ldapsearch -LLL -H ldap://192.168.56.10 -D "domain_administrator@sevenkingdoms.local" -w "domain_administrator" -b "DC=sevenkingdoms,DC=local" "(objectClass=*)" sAMAccountName
dn: DC=sevenkingdoms,DC=local
dn: CN=Users,DC=sevenkingdoms,DC=local
dn: CN=Computers,DC=sevenkingdoms,DC=local
dn: OU=Domain Controllers,DC=sevenkingdoms,DC=local
dn: CN=System,DC=sevenkingdoms,DC=local
dn: CN=LostAndFound,DC=sevenkingdoms,DC=local
dn: CN=Infrastructure,DC=sevenkingdoms,DC=local
dn: CN=ForeignSecurityPrincipals,DC=sevenkingdoms,DC=local
dn: CN=Program Data,DC=sevenkingdoms,DC=local
dn: CN=Microsoft,CN=Program Data,DC=sevenkingdoms,DC=local
dn: CN=NTDS Quotas,DC=sevenkingdoms,DC=local
dn: CN=Managed Service Accounts,DC=sevenkingdoms,DC=local
dn: CN=Keys,DC=sevenkingdoms,DC=local
dn: CN=WinsockServices,CN=System,DC=sevenkingdoms,DC=local
dn: CN=RpcServices,CN=System,DC=sevenkingdoms,DC=local
dn: CN=FileLinks,CN=System,DC=sevenkingdoms,DC=local
dn: CN=VolumeTable,CN=FileLinks,CN=System,DC=sevenkingdoms,DC=local
dn: CN=ObjectMoveTable,CN=FileLinks,CN=System,DC=sevenkingdoms,DC=local
dn: CN=Default Domain Policy,CN=System,DC=sevenkingdoms,DC=local
dn: CN=AppCategories,CN=Default Domain Policy,CN=System,DC=sevenkingdoms,DC=local
dn: CN=Meetings,CN=System,DC=sevenkingdoms,DC=local
```

Image 2.1a: Displays the command output in the terminal, showing each object's dn: line followed by the corresponding sAMAccountName attribute. This succinctly illustrates how many user and group accounts exist in the sevenkingdoms.local domain.

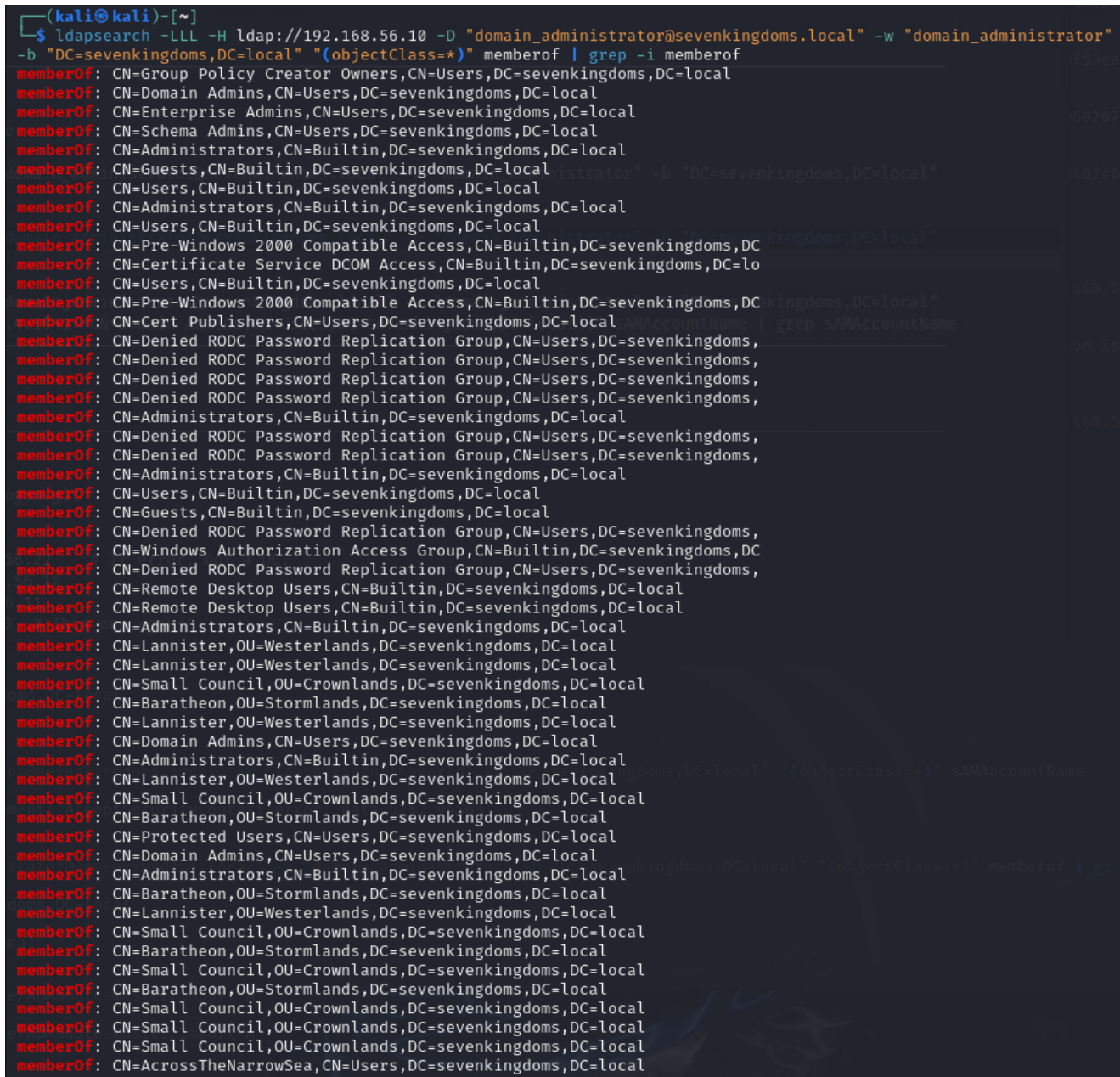
3.0 LDAP memberof Search

Command Used (IN POWERSHELL):

```
ldapsearch -LLL -H ldap://192.168.56.10 -D "domain_administrator@sevenkingdoms.local" -w "domain_administrator" -b "DC=sevenkingdoms,DC=local" "(objectClass=*)" memberof | grep -i memberof
```

Findings:

- Using ldapsearch to query memberof attributes (and filtering with grep) reveals each object's group memberships. The screenshot (Figure X) shows numerous built-in and custom groups (e.g., Domain Admins, Enterprise Admins, etc.) and which objects belong to them. This information is invaluable for identifying high-privilege groups and potential escalation paths within the sevenkingdoms.local domain.



```
(kali@kali)-[~]
$ ldapsearch -LLL -H ldap://192.168.56.10 -D "domain_administrator@sevenkingdoms.local" -w "domain_administrator" -b "DC=sevenkingdoms,DC=local" "(objectClass=*)" memberof | grep -i memberof
memberof: CN=Group Policy Creator Owners,CN=Users,DC=sevenkingdoms,DC=local
memberof: CN=Domain Admins,CN=Users,DC=sevenkingdoms,DC=local
memberof: CN=Enterprise Admins,CN=Users,DC=sevenkingdoms,DC=local
memberof: CN=Schema Admins,CN=Users,DC=sevenkingdoms,DC=local
memberof: CN=Administrators,CN=Builtin,DC=sevenkingdoms,DC=local
memberof: CN=Guests,CN=Builtin,DC=sevenkingdoms,DC=local
memberof: CN=Users,CN=Builtin,DC=sevenkingdoms,DC=local
memberof: CN=Administrators,CN=Builtin,DC=sevenkingdoms,DC=local
memberof: CN=Users,CN=Builtin,DC=sevenkingdoms,DC=local
memberof: CN=Pre-Windows 2000 Compatible Access,CN=Builtin,DC=sevenkingdoms,DC=local
memberof: CN=Certificate Service DCOM Access,CN=Builtin,DC=sevenkingdoms,DC=local
memberof: CN=Users,CN=Builtin,DC=sevenkingdoms,DC=local
memberof: CN=Pre-Windows 2000 Compatible Access,CN=Builtin,DC=sevenkingdoms,DC=local
memberof: CN=Cert Publishers,CN=Users,DC=sevenkingdoms,DC=local
memberof: CN=Denied RODC Password Replication Group,CN=Users,DC=sevenkingdoms,DC=local
memberof: CN=Denied RODC Password Replication Group,CN=Users,DC=sevenkingdoms,DC=local
memberof: CN=Denied RODC Password Replication Group,CN=Users,DC=sevenkingdoms,DC=local
memberof: CN=Denied RODC Password Replication Group,CN=Users,DC=sevenkingdoms,DC=local
memberof: CN=Administrators,CN=Builtin,DC=sevenkingdoms,DC=local
memberof: CN=Denied RODC Password Replication Group,CN=Users,DC=sevenkingdoms,DC=local
memberof: CN=Administrators,CN=Builtin,DC=sevenkingdoms,DC=local
memberof: CN=Users,CN=Builtin,DC=sevenkingdoms,DC=local
memberof: CN=Guests,CN=Builtin,DC=sevenkingdoms,DC=local
memberof: CN=Denied RODC Password Replication Group,CN=Users,DC=sevenkingdoms,DC=local
memberof: CN=Windows Authorization Access Group,CN=Builtin,DC=sevenkingdoms,DC=local
memberof: CN=Denied RODC Password Replication Group,CN=Users,DC=sevenkingdoms,DC=local
memberof: CN=Remote Desktop Users,CN=Builtin,DC=sevenkingdoms,DC=local
memberof: CN=Remote Desktop Users,CN=Builtin,DC=sevenkingdoms,DC=local
memberof: CN=Administrators,CN=Builtin,DC=sevenkingdoms,DC=local
memberof: CN=Lannister,OU=Westerlands,DC=sevenkingdoms,DC=local
memberof: CN=Lannister,OU=Westerlands,DC=sevenkingdoms,DC=local
memberof: CN=Small Council,OU=Crownlands,DC=sevenkingdoms,DC=local
memberof: CN=Baratheon,OU=Stormlands,DC=sevenkingdoms,DC=local
memberof: CN=Lannister,OU=Westerlands,DC=sevenkingdoms,DC=local
memberof: CN=Domain Admins,CN=Users,DC=sevenkingdoms,DC=local
memberof: CN=Administrators,CN=Builtin,DC=sevenkingdoms,DC=local
memberof: CN=Lannister,OU=Westerlands,DC=sevenkingdoms,DC=local
memberof: CN=Small Council,OU=Crownlands,DC=sevenkingdoms,DC=local
memberof: CN=Baratheon,OU=Stormlands,DC=sevenkingdoms,DC=local
memberof: CN=Protected Users,CN=Users,DC=sevenkingdoms,DC=local
memberof: CN=Domain Admins,CN=Users,DC=sevenkingdoms,DC=local
memberof: CN=Administrators,CN=Builtin,DC=sevenkingdoms,DC=local
memberof: CN=Baratheon,OU=Stormlands,DC=sevenkingdoms,DC=local
memberof: CN=Lannister,OU=Westerlands,DC=sevenkingdoms,DC=local
memberof: CN=Small Council,OU=Crownlands,DC=sevenkingdoms,DC=local
memberof: CN=Baratheon,OU=Stormlands,DC=sevenkingdoms,DC=local
memberof: CN=Small Council,OU=Crownlands,DC=sevenkingdoms,DC=local
memberof: CN=Small Council,OU=Crownlands,DC=sevenkingdoms,DC=local
memberof: CN=Small Council,OU=Crownlands,DC=sevenkingdoms,DC=local
memberof: CN=Small Council,OU=Crownlands,DC=sevenkingdoms,DC=local
memberof: CN=AcrossTheNarrowSea,CN=Users,DC=sevenkingdoms,DC=local
```

Image 3.0a: Displays the command's output, highlighting each dn: line followed by multiple memberof: entries. By grepping for "memberof," we quickly pinpoint the groups to which each object belongs, aiding in mapping out the AD group hierarchy and security model.

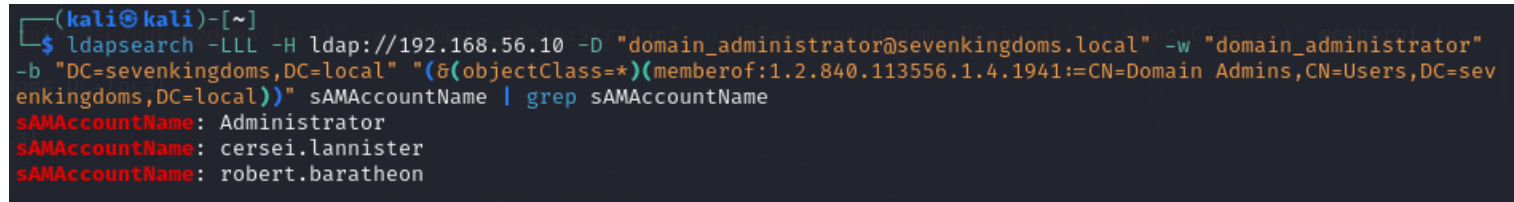
4.0 LDAP sAMAccountName Admin Search

Command Used (IN POWERSHELL):

```
ldapsearch -LLL -H ldap://192.168.56.10 -D "domain_administrator@sevenkingdoms.local" -w "domain_administrator" -b "DC=sevenkingdoms,DC=local" "(&(objectClass=*)(memberof:1.2.840.113556.1.4.1941:=CN=Domain Admins,CN=Users,DC=sevenkingdoms,DC=local))" sAMAccountName | grep sAMAccountName
```

Findings:

- This command uses the LDAP_MATCHING_RULE_IN_CHAIN (1.2.840.113556.1.4.1941) to list all members of the Domain Admins group, including those in nested groups. We see the sAMAccountName attributes for three privileged accounts: Administrator, cersei.lannister, & robert.baratheon, indicating each as Domain Admin rights.



```
(kali@kali)-[~]
$ ldapsearch -LLL -H ldap://192.168.56.10 -D "domain_administrator@sevenkingdoms.local" -w "domain_administrator" -b "DC=sevenkingdoms,DC=local" "(&(objectClass=*)(memberof:1.2.840.113556.1.4.1941:=CN=Domain Admins,CN=Users,DC=sevenkingdoms,DC=local))" sAMAccountName | grep sAMAccountName
sAMAccountName: Administrator
sAMAccountName: cersei.lannister
sAMAccountName: robert.baratheon
```

Image 4.0a: Displays the filtered sAMAccountName results. By applying grep, only the usernames are displayed, making it clear which accounts possess high-level privileges in the sevenkingdoms.local domain.

5.0 Nested User Creation

Command Used (IN CMD):

gpupdate /force

net group "Domain Admins" /domain

Findings:

- Creating a "Group A" and adding it to "Domain Admins" and then creating "Group B" and adding it to part of "Group A" and then adding user "NestedUser" into "Group B" creates a nested admin user. What is interesting is when we list domain admins using CMD, it does not seem to list our nested user. This is important because sometimes System Administrators can forget about old admin accounts created in unusual places, or if when an attacker tries to hide a backdoor admin user.

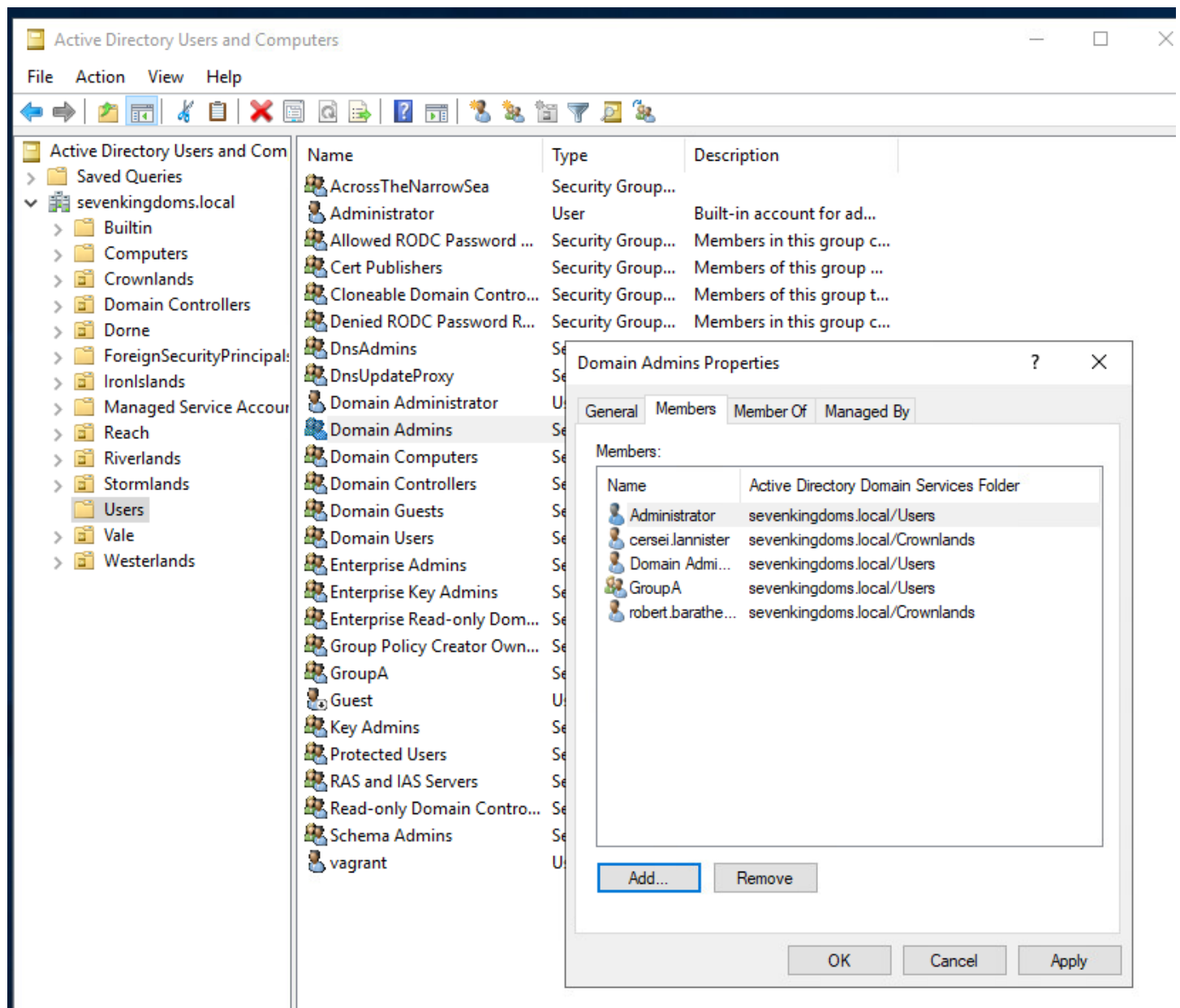


Image 5.0a: Displays creation of "Group A" and adding "Group A" to the "Domain Admins" group.

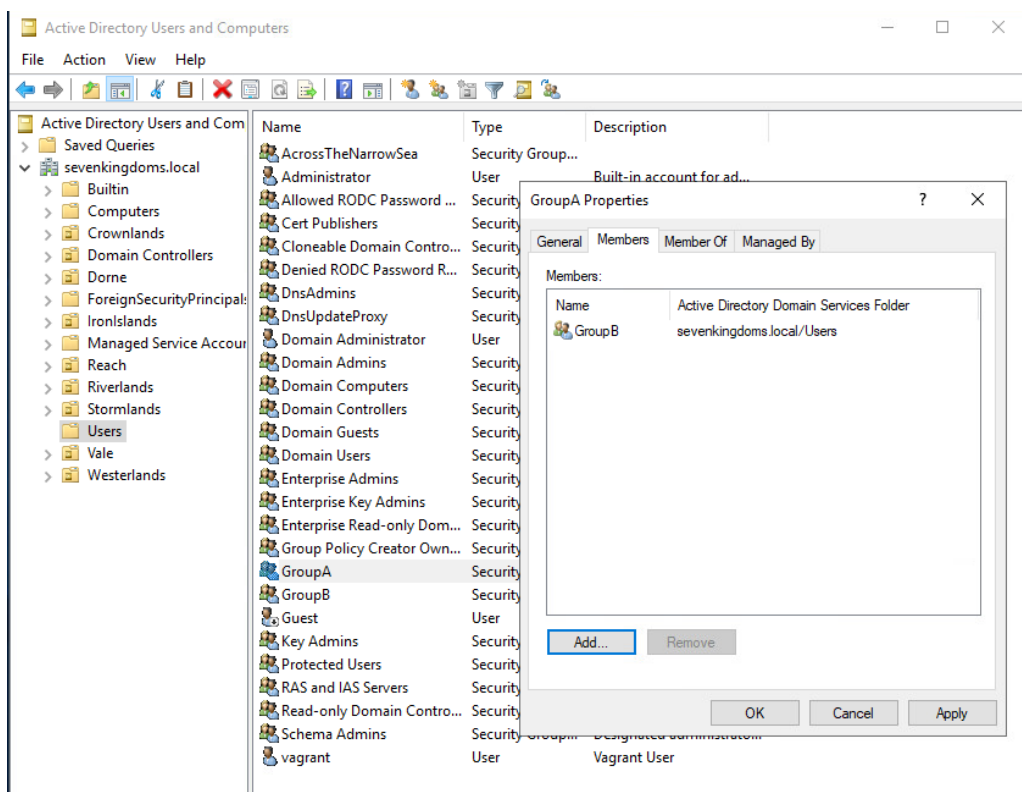


Image 5.0b: Displays creation of “Group B” and adding “Group B” to the “Group A” group.

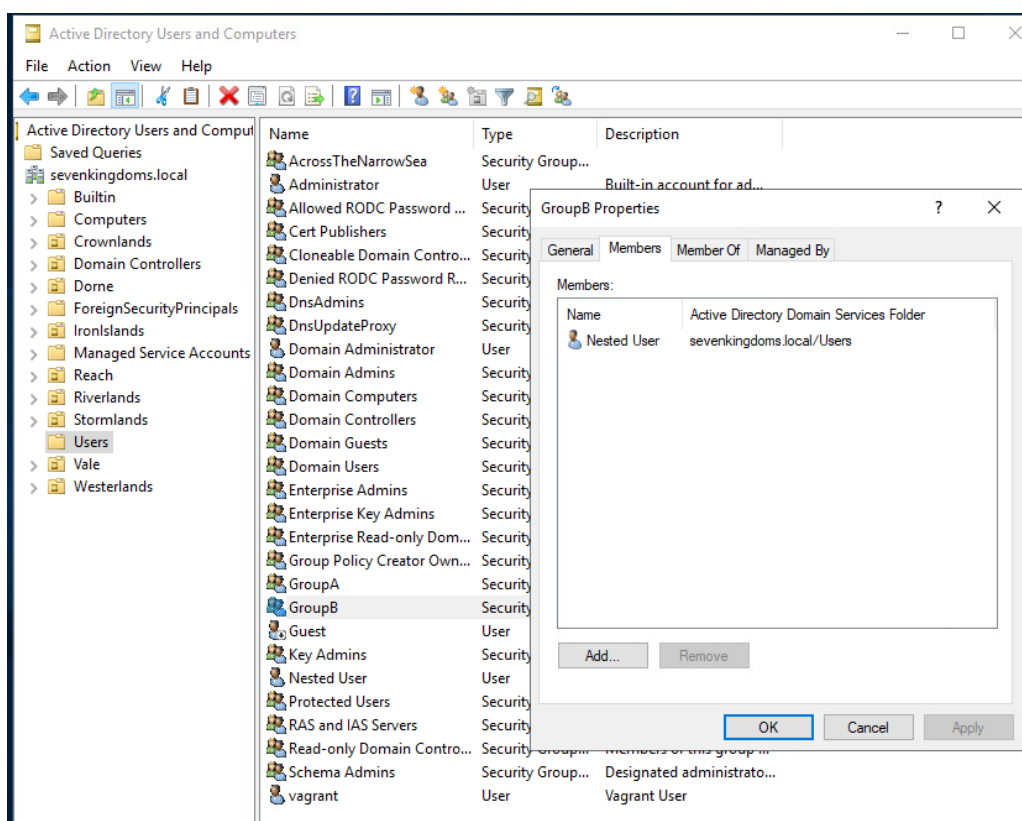


Image 5.0c: Displays creation of “NestedUser” and adding that user to “Group B” group.

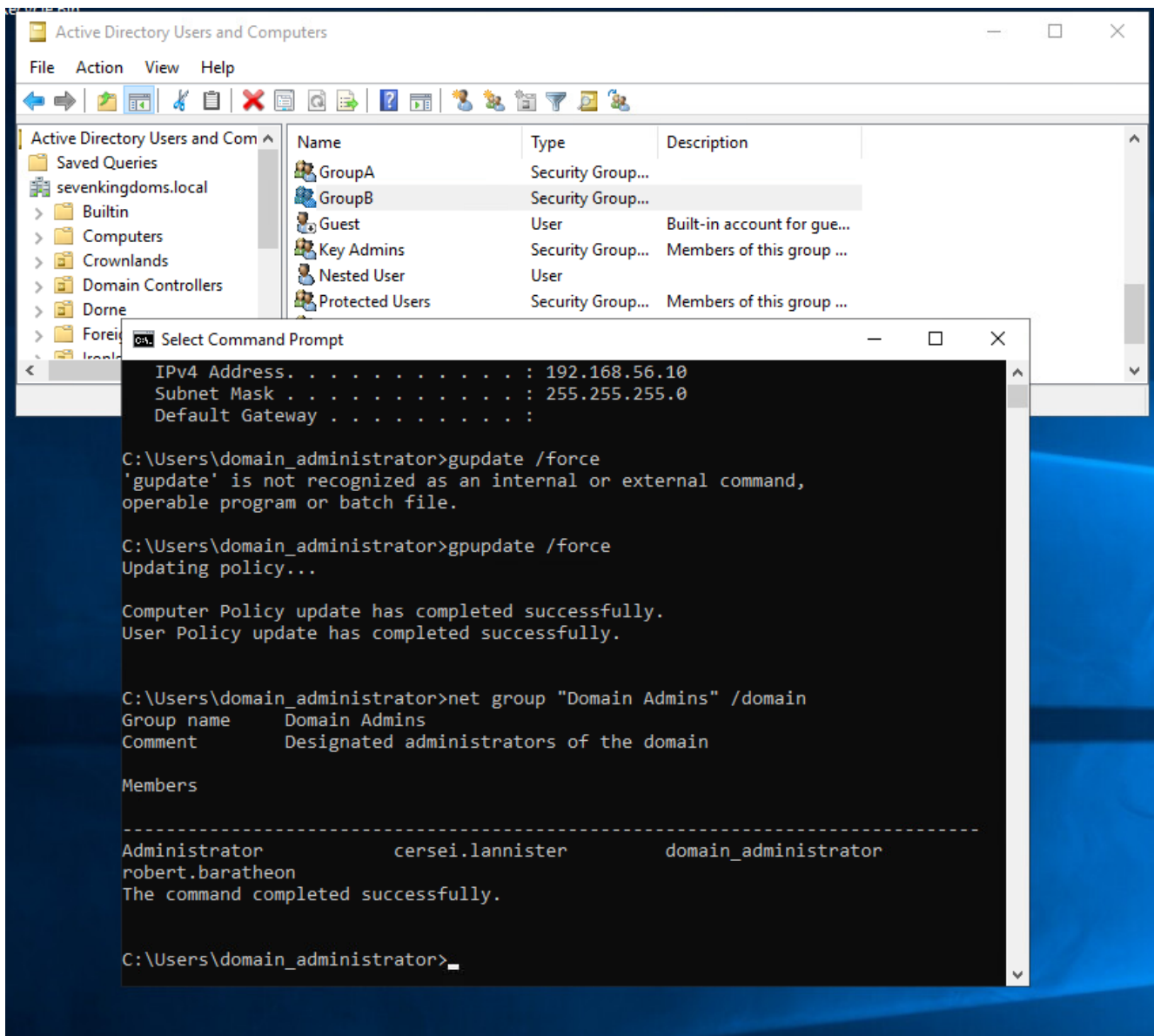


Image 5.0d: Displays all Domain Admins using a CMD command (notice our nested user does not appear) .

6.0 LDAP Search and Windapsearch

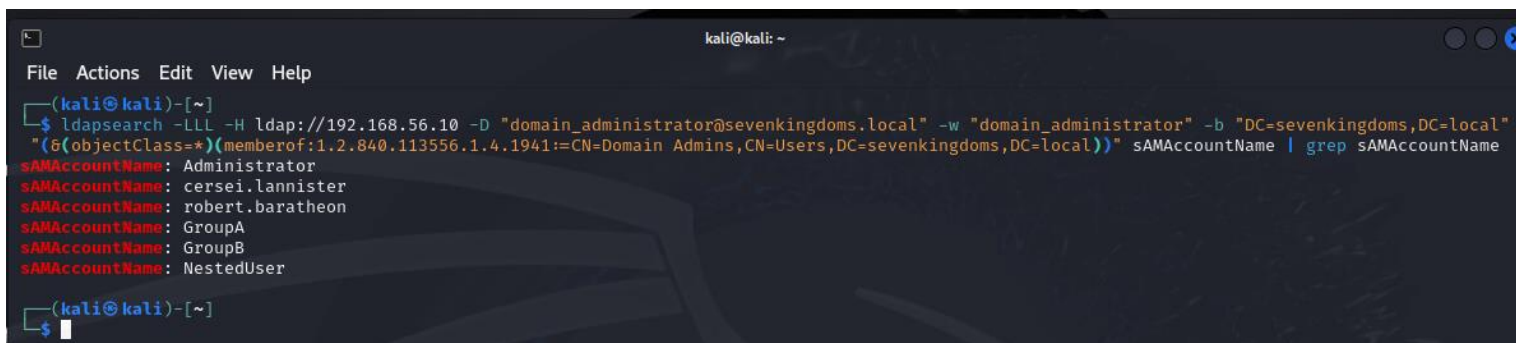
Command Used (IN KALI):

```
ldapsearch -LLL -H ldap://192.168.56.10 -D "domain_administrator@sevenkingdoms.local" -w "domain_administrator" -b "DC=sevenkingdoms,DC=local" "(&(objectClass=*)(memberof:1.2.840.113556.1.4.1941:=CN=Domain Admins,CN=Users,DC=sevenkingdoms,DC=local))" sAMAccountName | grep sAMAccountName
```

```
windapsearch/windapsearch.py -d sevenkingdoms.local -dc-ip 192.168.56.10 -u domain_administrator@sevenkingdoms.local -p "domain_administrator" --users
```

Findings:

- Both tools retrieved AD user information: The ldapsearch and windapsearch outputs confirm the presence of valid sAMAccountName entries, demonstrating that user accounts in the domain are successfully enumerated.
- Differences in presentation: While ldapsearch produced a raw, detailed output, windapsearch delivered a more streamlined, formatted view optimized for AD enumeration, making it easier to interpret high-level information.



```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ ldapsearch -LLL -H ldap://192.168.56.10 -D "domain_administrator@sevenkingdoms.local" -w "domain_administrator" -b "DC=sevenkingdoms,DC=local" "(&(objectClass=*)(memberof:1.2.840.113556.1.4.1941:=CN=Domain Admins,CN=Users,DC=sevenkingdoms,DC=local))" sAMAccountName | grep sAMAccountName  
sAMAccountName: Administrator  
sAMAccountName: cersei.lannister  
sAMAccountName: robert.baratheon  
sAMAccountName: GroupA  
sAMAccountName: GroupB  
sAMAccountName: NestedUser  
(kali@kali)-[~]  
$
```

Image 6.0a: Displays output of the ldap search.

```
kali@kali: ~  
File Actions Edit View Help  
$ windapsearch/windapsearch.py -d sevenkingdoms.local --dc-ip 192.168.56.10 -u  
domain_administrator@sevenkingdoms.local -p "domain_administrator" --users  
[+] Using Domain Controller at: 192.168.56.10  
[+] Getting defaultNamingContext from Root DSE  
[+] Found: DC=sevenkingdoms,DC=local  
[+] Attempting bind  
[+] ... success! Binded as:  
[+] u:SEVENKINGDOMS\domain_administrator  
[+] Enumerating all AD users  
[+] Found 19 users:  
cn: Administrator  
cn: Guest  
cn: vagrant  
cn: krbtgt  
cn: NORTH$  
cn: ESSOS$  
cn: tywin.lannister  
cn: jaime.lannister  
cn: cersei.lannister  
cn: tyron.lannister  
cn: robert.baratheon  
cn: joffrey.baratheon  
cn: renly.baratheon  
cn: stannis.baratheon  
cn: petyer.baelish  
cn: lord.varys  
cn: maester.pycelle  
cn: Domain Administrator  
userPrincipalName: domain_administrator@sevenkingdoms.local  
cn: Nested User  
userPrincipalName: NestedUser@sevenkingdoms.local  
[+] Bye!
```

Image 6.0b: Displays output of the windapsearch.